

EKSAMEN

Emnekode: ITF15019

Emnenavn: Innføring i datasikkerhet

Dato: 30/04-2025

Eksamenstid: 09.00-13.00, 4 timer.

Hjelpemidler:

Ingen

Faglærere: Tom Heine Nätt og Ole-Edvard Ørebæk

Om eksamensoppgaven:

Oppgavesettet består av **6** hovedoppgaver med hvert sitt overordnede tema, og et antall deloppgaver. Det er angitt på hver hovedoppgave hvor mye denne i prosent teller av totalen. Vektingen av deloppgaver internt i en hovedoppgave vil reflektere omfanget av deloppgaven, men er ikke angitt eksplisitt.

Selv om hovedoppgavene har angitt en omtrentlig vekting, så er det viktig å påpeke at karakteren fastsettes basert på en helhetlig vurdering av besvarelsen.

NB! Sørg for å besvare deloppgavene separat, markert tydelig med bokstaven på deloppgaven du besvarer. Sensuren vil ikke "flytte svar" mellom deloppgaver eller hovedoppgaver der de virker å høre bedre hjemme. Besvar derfor heller ikke deloppgavene samlet slik som "a og b) ...".

For å forenkle sensuren, samt øke din egen struktur på svarene, er det en stor fordel å besvare flere av oppgavene som punktlistor. Det er angitt eksplisitt der dette er spesielt nyttig/forventet, men kan gjøres i de fleste oppgavene dersom du ønsker. Lag gjerne listene på følgende måte:

- **Oppsummert tittel:** Utdypende beskrivelse på en eller flere setninger
- **Oppsummert tittel:** Utdypende beskrivelse på en eller flere setninger

Gjør dine egne forutsetninger dersom du mener noe er uklart i oppgavene.

Takk for et hyggelig semester - beklager at vi har gjort dere paranoide...

Lykke til!

Sensurfrist: 22/05-2024

Karakterene blir tilgjengelige for studenter på Studentweb.

¹ Oppgave 1 - Bedrifter/Personvern/Risikoanalyse - 20 %

- a) Forklar hva som menes med risiko og hvordan dette fastsettes (dvs. hva fastsettes risiko ut ifra). Hvorfor er det praktisk å snakke om/benytt risiko? (ordet risiko brukt i forbindelse med å angi "hvor farlig" noe er, ikke "typer hendelser" som enkelte gjør)
- b) Hvilke gevinster kan man oppnå ved å gjøre en risikoanalyse? (Besvar gjerne spørsmålet som en punktliste)
- c) Forklar hvordan GDPR har påvirket bedrifter og bedrifters sikkerhetsarbeid. (Besvar gjerne spørsmålet som en punktliste)
- d) Drøft kort hvordan det at bedriftene belager seg på samtykker i enkelte situasjoner kan være til ulempe for brukerne.
-
- a) Risiko er en mulig, uønsket hendelse som inntreffer og fører til tap av konfidensialitet, integritet og/eller tilgjengelighet. Risiko fastsette fra formelen sannsynlighet * konsekvens. Det er praktisk å snakke om/benytt risiko fordi vi er biologisk programmert til å handle med konkrete, fysiske trusler
- b) * bedre beslutningsgrunnlag: å kartlegge mulige feilpunkter kan gi folk et realistisk bilde over situasjonen og lettere strukturere prioriteringer istedenfor å gjette.
- Proaktivitet istedenfor reaktivitet: istedenfor å håndtere konsekvensene av hendelser, kan man heller unngå konsekvensene. Dette kan spare tid til andre viktige ting ved å forutse feil/problemer og øke sikkerhet ved å fjerne risiko.
 - Økonomisk besparelse: kortsiktig vil det koste mye å iverksette tiltak, men langsiktig vil man unngå bøter ved lovbrudd, lavere vedlikeholdskostnad, saksøknader, osv.
 - Økt trygghet og bedre arbeidsmiljø: iverksetting av en trygghetskultur fører til tryggere miljø og mennesker som forsterker kulturen som igjen bedrer miljøet og menneskene, og fortsetter løkken.
- c) * økt og bedre trygghetskultur: GDPR forstørker konsekvensene ved å gi større økonomisk straff, gi flere og større plikter, gi brukere mer rettigheter, osv., samt øke sannsynligheten ved å kreve internkontroll og ansvar, kreve at alle virksomheter i «kjeden» følger GDPR, kreve at personvern/informasjonsikkerhet integreres i systemet fra starten, osv. slik at kostnadene av mottiltakene virker rimeligere.
- Markedstilgang: ved å ikke ha den trygghetskulturen vil ikke-EU/EØS-bedrifter gå glipp av en mulig mengde inntekt og marked, som igjen kan føre til bedriftene motvillig følger GDPR som igjen fører til tryggere og sikrere kultur utenfor EU/EØS.
 - Proaktivitet: tvinge bedrifter til å ha internkontroll og tenke sikkerhet fra starten.
- d) At bedriftene belager seg på samtykker i enkelte situasjoner kan være til ulempe for brukerne fordi da kan de få flere rettigheter. Før GDPR var det en tydelig liste over hva som er tillat og ikke tillat i ulike sammenhenger, men med GDPR kunne listen over tillatelse bli stor så lenge brukeren ga samtykke, selv i sammenhenger man ikke samtykket til men likevel ga fordi hva som inkluderes i samtykket ligger i en lang, oppfattende kjedelig tekst som brukere kanskje skimleser og umiddelbart trykker «samtykk». i tillegg finnes det en maktubalanse mellom brukere og tjenester hvor man ikke har valgfrihet p.g.a. tvunget givelse av samtykke for å ikke miste tilgang til tjenester.

Maks poeng: 10

² Oppgave 2 - Skadevare - 20 %

- a) Velg deg ut 3 ulike hovedtyper skadevare, og forklar hva som kjennetegner hver type. Fokuser på de fire områdene *spredning*, *stridshode*, *nyttelast* og *kamouflasje* (de som er aktuelle) i svaret.
- b) Hva er et botnett, og hva kan botnett benyttes til? (Besvar gjerne siste halvdel av spørsmålet som en punktliste)

- Gjør en gjennomgang av ulike hovedmetoder for å oppdage skadevare (fokuser mest på tekniske metoder benyttet av antivirusverktøy)
- Hva kan gjøre fjerning av skadevare utfordrende? (Besvar gjerne spørsmålet som en punktliste).

a) virus:

- spredning: manuell interaksjon, f.eks. nedlastning, trenger en vertdokument/-fil
- stridshode: åpne en infisert vertdokument/-fil
- nyttelast: kopiere seg inn i andre filer, programmer, osv., ellers hva som helst
- kamouflasje: kopiere seg inn i legitim kode

ormer:

- spredning: bruke nettverk og selv-replikerer
- stridshode: utnyttelse av sikkerhetshull
- nyttelast: spre seg fort, ellers hva som helst
- kamouflasje: usynlig, gjemme seg som legitim prosess

trojaner:

- spredning: sosial manipulasjon, manuell interaksjon
- stridshode: manuell interaksjon, f.eks. kjøre program
- nyttelast: presis og målrettet angrep, ellers hva som helst
- kamouflasje: etterlikne legitim kode, program, osv. eller gjemme seg i dem

b) botnett er et nettverk av infiserte enheter kontrollert av angriperen(e). brukes til:

- * (D)Dos-angrep
- * spredning av skadevarer
- * propagandakampanjer
- * villedning
- * angrep i stor skala

c) signaturbasert deteksjon: sammenlikne kodebiter med kodebiter fra kjente skadevarer. Metoden er rask, effektiv og ofte «feilfritt», men signaturfilen må oppdateres konstant, er ikke effektiv mot poly-/metamorfiske/tilfeldige skadevarer eller kryptering, og kartlegger skadevarer først etter hendelsen(e) skjedde.

heuristikk: bruke parametere og grenseverdier for å sjekke om noe er en skadevare. Metoden finner «ukjente» skadevarer, men sliter med «falske» treff og kan bli lettlurt

anomalibasert deteksjon: fungerer som heuristikk, men ser etter avvik fra normalen. Metoden finner ukjente skadevarer, mindre avhengig av å få oppdateringer om skadevarenes struktur og tilpasser seg rundt «det normale», men hva som er «det normale» kan utnyttes ved å gjøre små endringer for at deteksjonen gradvis tilvenner seg «det nye normalen». I tillegg krever dem tid for å vite hva som er normal.

snubletråder: sammenlikne kontinuerlig maskiner, programmer, filer, osv. med en kopi av en tidligere, ønsket tilstand av dem. Metoden effektivt oppdager og varsler om skadevare finnes, spesielt usynlige skadevarer som rootkits (gjemmer seg i OS-ens kjerne), integritet brytes eller generell uønsket endringer skjer. Metoden kan gi «falske» treff og er reaktiv, som vil si at metoden aktiveres etter at en hendelse skjer.

d)

- konsekvenser: å fjerne skadevarer vil ikke fjerne konsekvensene (nyttelasten)
- spredning: selv om skadevaren fjernes, så kan den komme tilbake gjennom back-ups eller andre filer.
- Tilleggsfjerning: vanskelig å bare fjerne skadevarer uten å fjerne filene, programmene, osv. som er infisert av skadevarene
- Dynamisk: skadevaren kan endre sin kjernekode slik at å oppdage logikken blir vanskelig (metamorfisme) eller endre sin «ytte skall», f.eks. kryptering (polymorfisme).
- Selvforvar og utholdenhet: hvis tilhørende filer, programmer, osv. fjernes, så kan skadevarene starte en prosess for å gjenopprette dem, eller så kan skadevarene påvirke registeret for hvilke prosesser skal startet ved maskinens oppstart for å aktivere skadevaren igjen.

Maks poeng: 10

³ Oppgave 3 - Nettvett - 10 %

Drøft hvordan *andres datasikkerhet* kan påvirke deg. Her er det mange svar, og mye av pensum passer. Gi minst ett konkret eksempel i tillegg til den generelle drøftingen.

Forsyningskjeden: man kan ha god sikkerhet og fortsatt bli utsatt fordi tjenesten man valgte å bruke selv blir hacket, svindlet, osv.. f.eks. facebook, snapchat, osv. sine sikkerhetsmekanismer blir unngått og all data om kundene blir lekket.

Sosiale nettverk og tillit: noen bekjente, f.eks. din venns konto, blir tatt over, brukes i et angrep mot deg, f.eks. spear phishing, og misbruker ens tillit til den bekjente for å dele skadevare og infisere en maskin.

IoT og «zombienettverk»: kameraer, lyspærer, osv. kan bli hacket og brukes for angrep av tjenester/infrastruktur. F.eks. (D)Dos-angrep mot banken eller være en mellommann som overfører stjålet informasjon og dekke sine spor.

Samfunnskritiske tjenester og infrastruktur: banken, kommunens system, sykehuset, osv. blir angrepet, f.eks. ransomware eller lekkasje av data, som fører til mistet evne til å bruke tjeneste, f.eks. tjenestens system er nede.

Maks poeng: 10

⁴ Oppgave 4 - Webteknologi - 20 %

a) Forklar kort hvordan symmetrisk og asymmetrisk kryptering, samt sertifikater, benyttes i HTTPS for å oppfylle HTTPS sine oppgaver.

b) Forklar begrepet SQL-Injection.

c) Forklar begrepet Cross-Site Scripting (XSS).

d) Forklar hva tjenesteleverandører kan gjøre for å redusere sannsynligheten for angrep med metoder slik som SQL-Injection og Cross-Site Scripting? (besvar gjerne spørsmålet som en punktliste)

- a)
1. bli enig om krypteringsalgoritme
 2. klienten sender en tilkoblingsforespørsel
 3. serveren sender et sertifikat med sin identifikasjon

4. klienten (sjeldent serveren) validerer serverens (sjeldent klientens) sertifikatet ved å bruke sertifikatets offentlige nøkkel
 5. klienten bruker symmetrisk kryptering for sesjonsnøkkelen
 6. klienten bruker asymmetrisk for å utveksle sesjonsnøkkelen
 7. serveren bruker sin private nøkkel for å se sesjonsnøkkelen
 8. bruker sesjonsnøkkelen for videre kommunikasjon
- b) SQL-injection er når angriperen utnytter bruker-input for å sende uautorisert SQL-kommandoer. F.eks. sende kommando for å gi info om alle kontoene, og kommandoen valideres ikke.
- c) CSS/XSS er når script sendes fra klientsiden til serversiden/nettsiden og lurer dem til å kjøre script-en. F.eks. sende en kode gjennom en bruker-input og input-en valideres ikke og dermed limer den inn i sin kode slik at neste gang en bruker laster inn siden, så vil den innlimt kode kjøres og stjele cookies.
- d)
- Input-validering: whitelisting/blacklisting, parametriserte spørringer, mønster (regex), lengde, filtrere under output og input, osv.
 - Privilegium: brukere skal ha minst mulig tillatelser for å gjøre sine oppgaver
 - Content Security Policy (CSP): en sikkerhetsskjold som forteller nettlesere at de skal kjøre script bare fra egne servere.
 - Regelmessig skanning og pen-testing: la «snille» hackere finne sikkerhetshull

Maks poeng: 10

⁵ Oppgave 5 - Maskiner, Programvare og Datalagring - 20%

- a) Hvordan kan noen med fysisk tilgang omgå låseskjermen på en stasjonær datamaskin? (Her kan det nevnes flere muligheter. Besvar gjerne spørsmålet som en punktliste)
- b) Gjør en gjennomgang av ulike utfordringer ved bruk av skytjenester. (Besvar gjerne spørsmålet som en punktliste)
- c) Forklar kort hvorfor det er vanskelig å permanent slette data fra lagringsmedier, og hva kan man gjøre for å få til dette.
- d) Beskriv hva metadata er. Hvorfor er det viktig å være bevisst på slike data?
- a)
- * Ha en live-/boot-usb/cd installert med en annen OS med cracking-programvare
 - Ta ut lagringsmediet, koble til en annen pc eller en dedikert enhet for å skanne innholdet med en programvare
- b)
- * tillit: man må stole på at leverandøren gjør back-ups av dataene
 - Sikkerhet og personvern: man flytter kontroll over data og dermed håpe at leverandøren sikrer dataene dine korrekt, hvem som har tilgang til dataene og hindre lekkasje eller hacking
 - Avhengighet av leverandør: vil bli vanskelig, komplisert, osv. for en bruker og/eller leverandør for å overføre data mellom andres databaser, som fører til tvang av å måtte bruke valgt leverandør
 - Tilgjengelighet: forbindelsen mellom brukerne og tjenesten må være stabil og leverandører må sikre at tjenesten aldri får nedetid
- c) det er vanskelig å permanent slette data fra lagringsmedier fordi det man egentlig sletter er tilkoblingen mellom et register av hvor data er lagret og selve dataen. Når tilkoblingen er borte så er dataen fortsatt der, men nå har muligheten for å overskrive dataen. For å «slette» data kan man gjøre en diskwipe hvor dataen blir overskrevet av tilfeldig data, «manuell» overskriving eller ødelegge lagringsmediet.
- d) Metadata er tilleggsdata lagret med hoveddata. Tilleggsdataene kan være gps-koordinatene, opprettelsesdato, kameraspesifikasjoner, størrelse, osv. Det er viktig å være bevisst på slike

data fordi de kan misbrukes for å kombinere dataene med andre data for å få nøyaktig informasjon om deg, f.eks. hvem du er, og krenke personvernet ditt, f.eks. stalking.

Maks poeng: 10

⁶ Oppgave 6 - KI og datasikkerhet - 10%

Drøft hvorfor og hvordan kunstig intelligens er en stor ny trussel innen datasikkerhet.

Hvorfor:

- Demokratisering av hacking: KI senker terskelen for å begå avansert datakriminalitet. En person med begrenset programmeringskunnskap kan nå bruke KI-verktøy til å generere skadelig kode eller planlegge komplekse angrep.
- Skalerbarhet: Tidligere krevde målrettede angrep (som "spear phishing") mye manuelt arbeid. Med KI kan angripere sende ut tusenvis av personlige og overbevisende meldinger samtidig.
- Hastighet: KI kan analysere sårbarheter i et nettverk og eksekvere et angrep på brøkdelen av tiden det tar et menneske, noe som gjør det vanskelig for tradisjonelle forsvarssystemer å respondere raskt nok.
- Omgår menneskelig intuisjon: Vi er trent til å se etter skrivefeil eller merkelig språk i svindelforsøk. KI fjerner disse avslørende tegnene, noe som gjør at vi ikke lenger kan stole på magefølelsen.

Hvordan:

- Avansert Phishing og Sosial Manipulasjon

KI kan generere tekst som er språklig perfekt og tilpasset offerets kontekst ved å høste data fra sosiale medier.

- Deepfakes: Bruk av KI for å etterligne stemmer (voice cloning) eller ansikter i videosamtaler for å lure ansatte til å overføre penger eller gi fra seg passord.

- Automatisert utvikling av skadevare (Malware)

Angripere bruker store språkmodeller til å skrive, feilsøke og forbedre ondsinnet kode.

- Polymorf kode: KI kan bidra til å lage skadevare som endrer sin egen signatur kontinuerlig for å unngå å bli oppdaget av tradisjonelle antivirusprogrammer.

- Intelligent sårbarhetsskanning

KI-algoritmer kan skanne enorme mengder programvarekode eller nettverkskonfigurasjoner for å finne "null-dagers sårbarheter" (ukjente hull) raskere enn sikkerhetsanalytikere klarer å tette dem.

- Kneking av passord og autentisering

KI kan brukes til å forutse passordmønstre mer effektivt enn tradisjonelle "brute force"-metoder ved å lære av eksisterende lekkasjer og menneskelig psykologi.

Maks poeng: 10

